



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

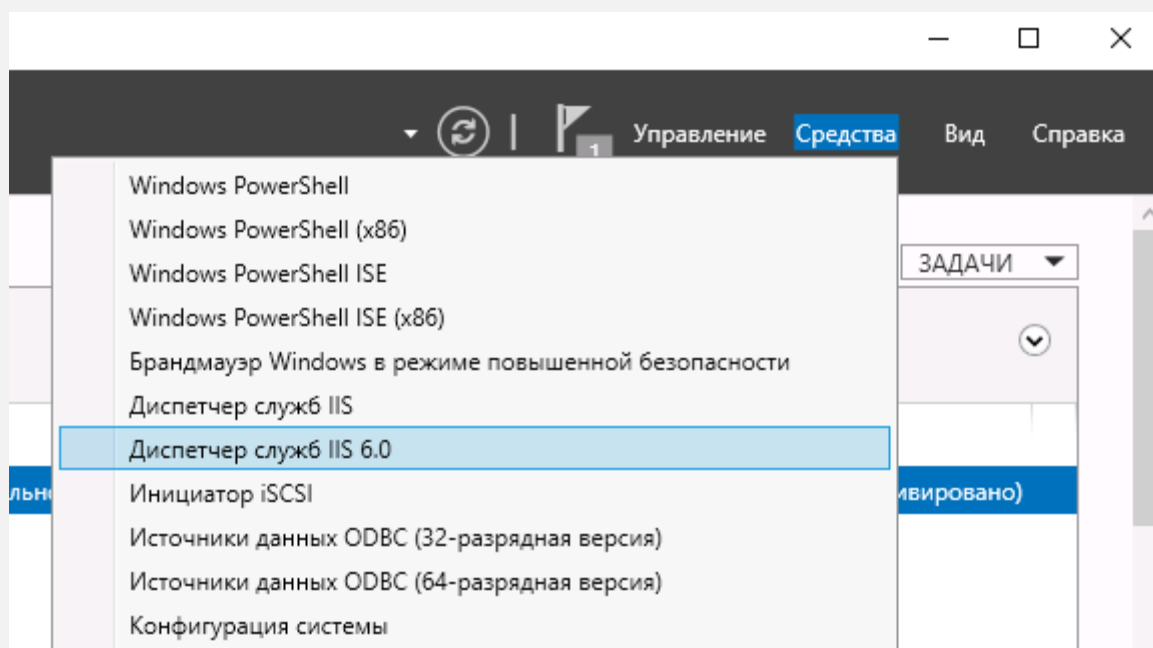
Друзья, всем доброго времени суток! В этом уроке мы поговорим про эnumерацию [SMTP](#).

Подготовка к уроку

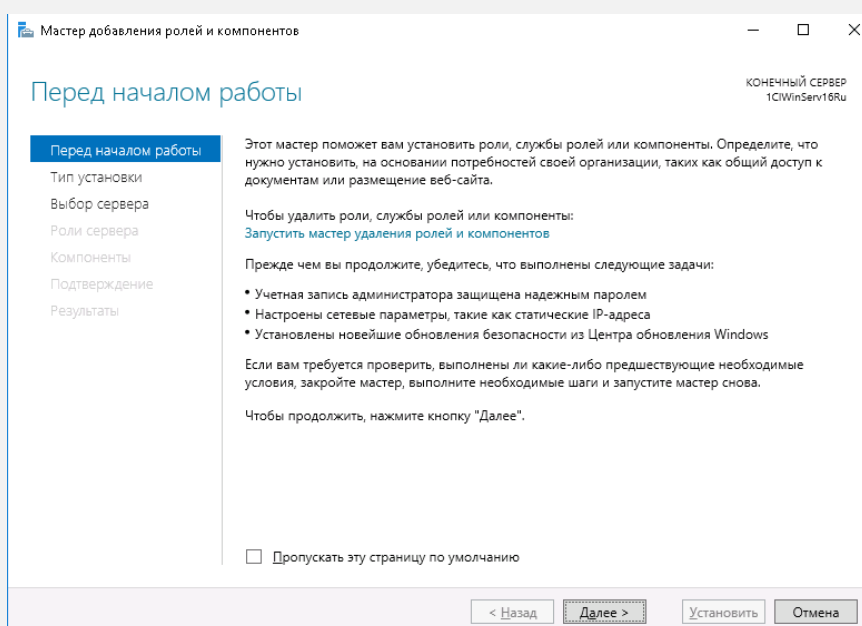
[Скачиваем](#) и [устанавливаем](#) Windows Server 2012 R2 на Virtual Box (P.S. Windows Server мы устанавливали в предыдущем уроке!).

Установка и настройка SMTP-сервера

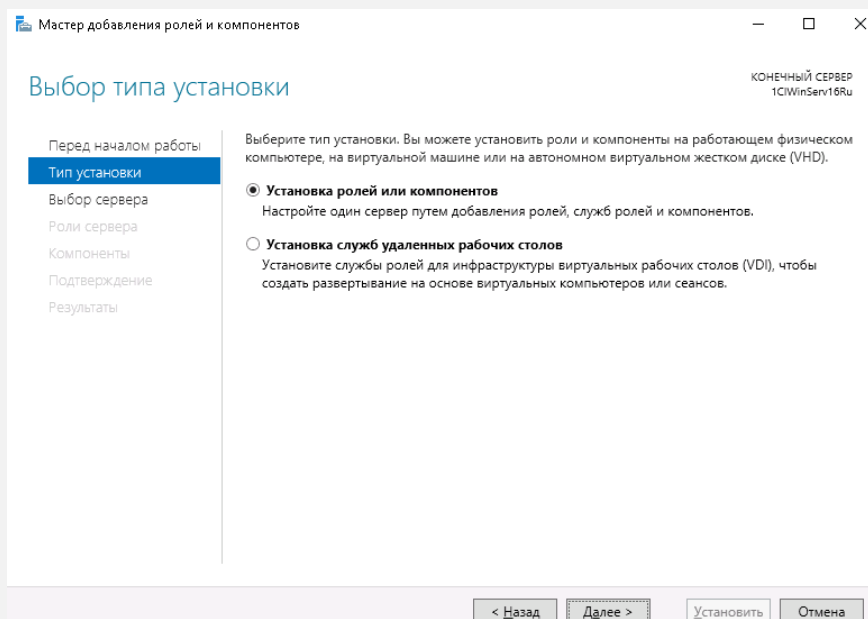
Установка



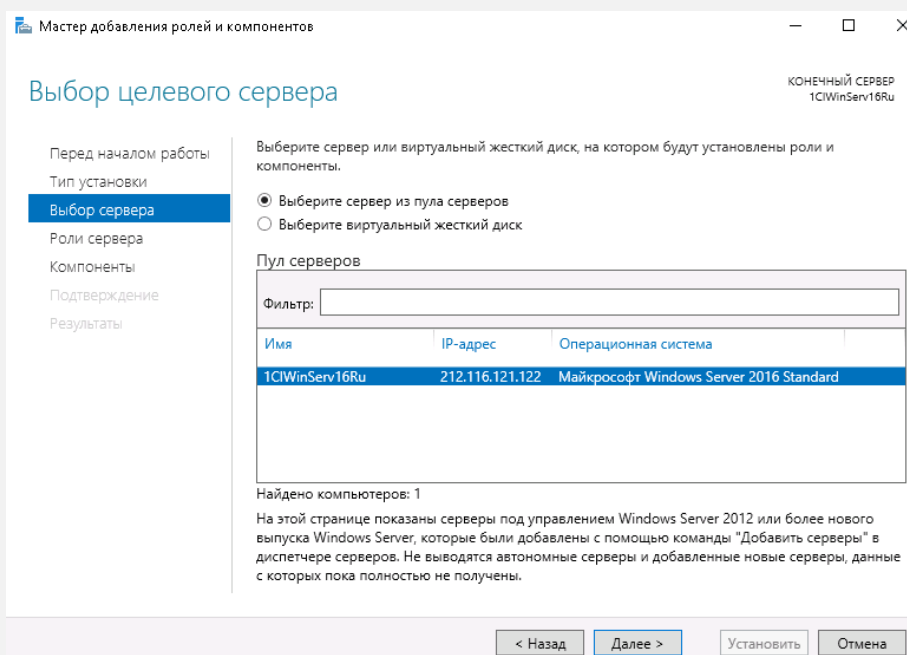
Для начала необходимо добавить недостающие компоненты.



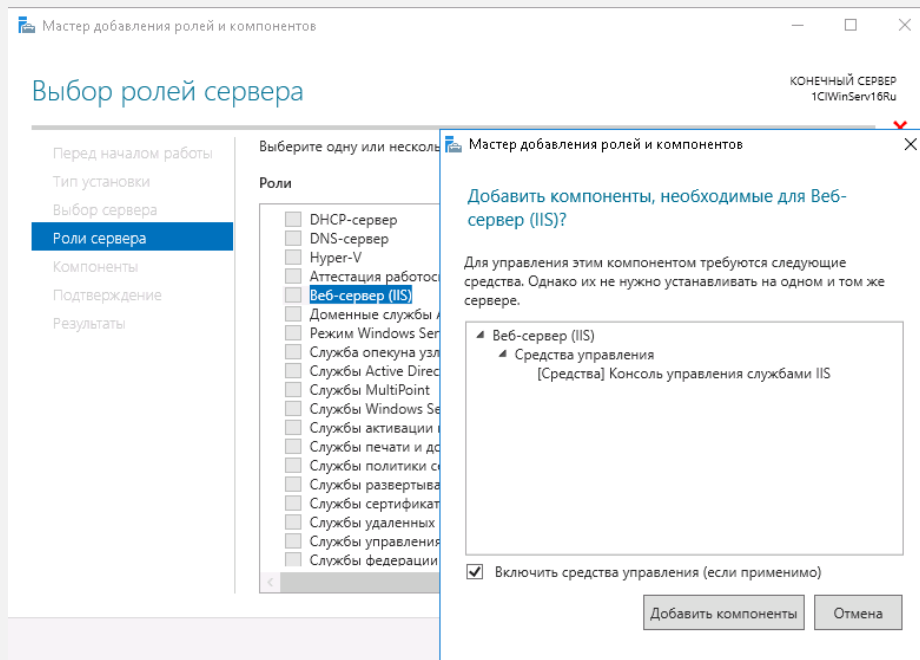
Выберете “Установка ролей и компонентов” и нажмите “Далее”.



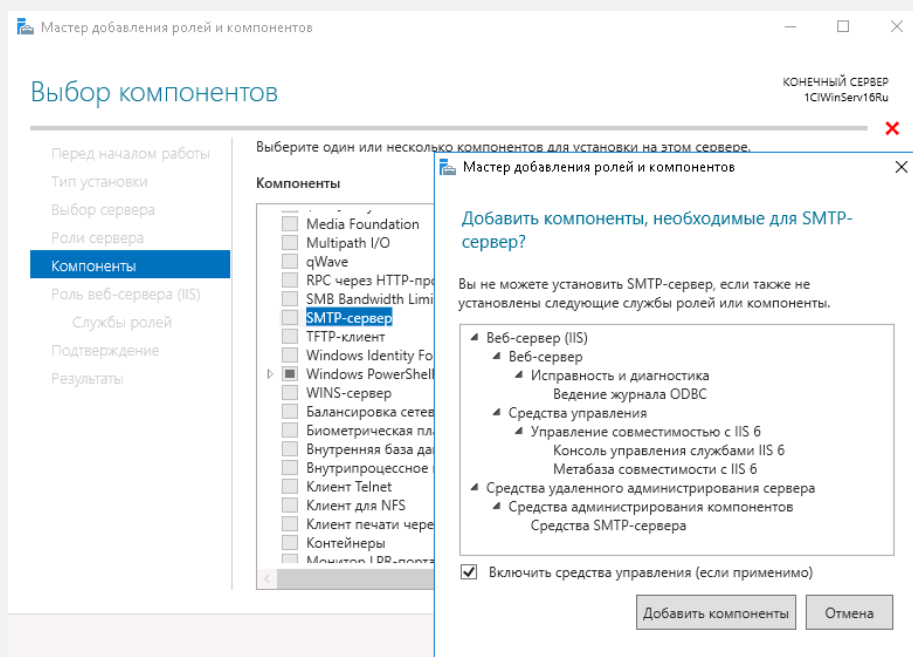
Выберете нужный сервер из пула.



На следующем шаге выберете роль “Веб-сервер (IIS)”. В открывшемся окне нажмите “Добавить компоненты”. Веб-сервер (IIS) содержит консоли для управления службой SMTP.



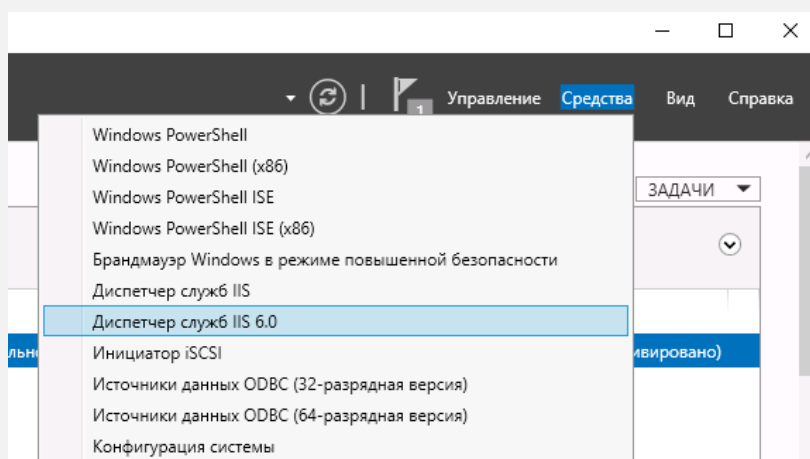
Далее в списке компонентов выберете “SMTP-сервер”. В открывшемся окне нажмите “Добавить компоненты”.



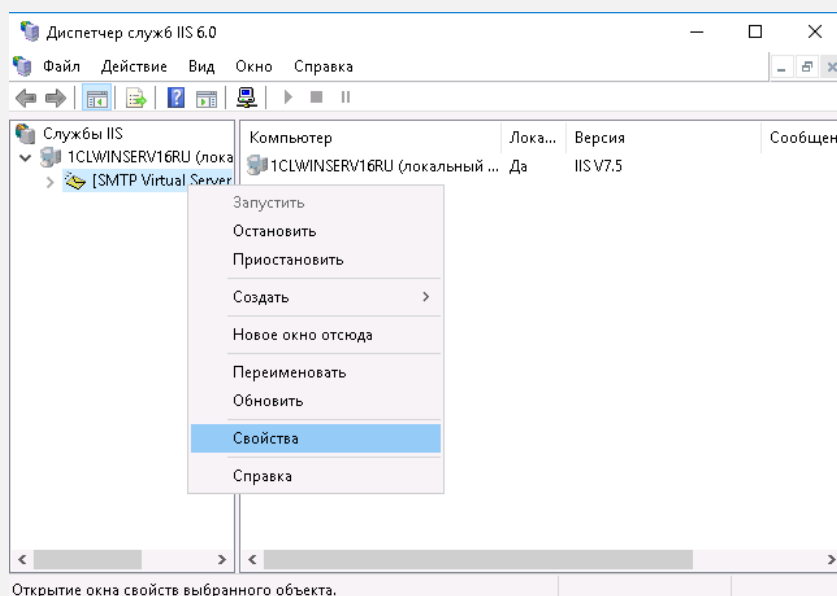
На следующих шагах примите настройки по умолчанию и выполните установку. Перезагрузка сервера не требуется.

Настройка

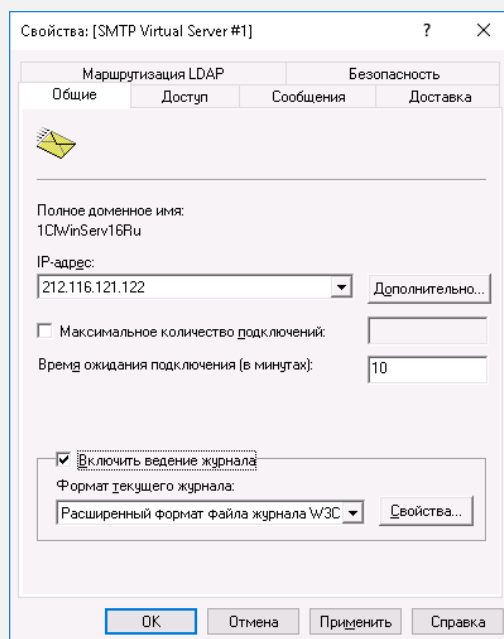
Управлять SMTP сервером можно через Internet Information Services (IIS) Manager 6. Чтобы открыть IIS, перейдите в диспетчер серверов и в меню в правом верхнем углу выберите раздел “Средства” -> “Диспетчер служб IIS 6.0”.



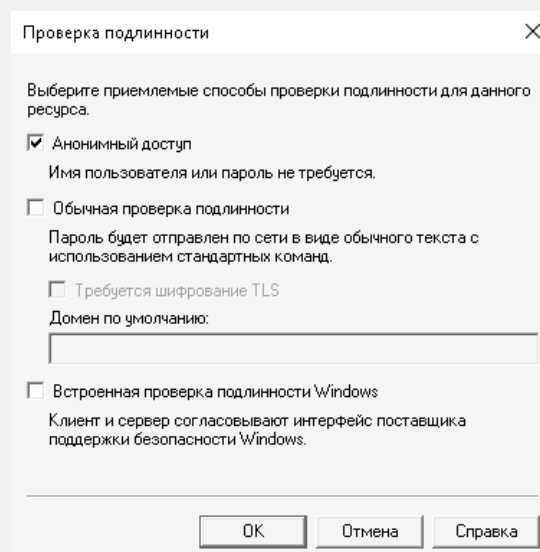
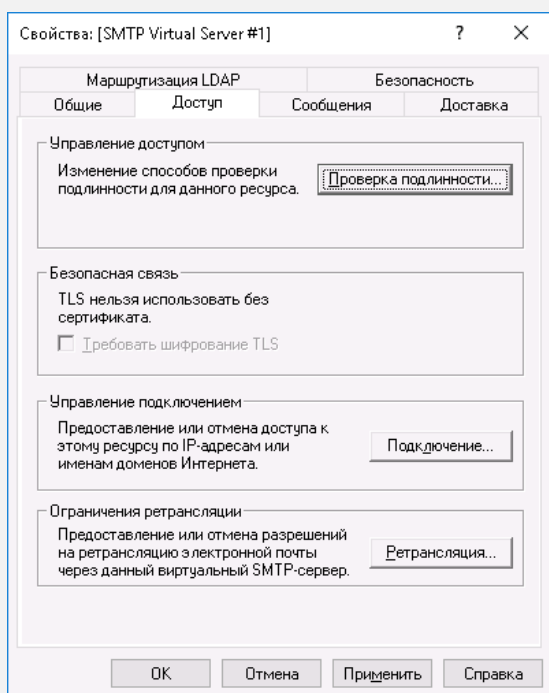
Разверните ветку с именем сервера, выберите SMTP Virtual Server и откройте его свойства.



На вкладке “Общие” выберите ваш IP-адрес, на котором должен отвечать SMTP сервер и включите ведение журнала, для сохранения информации обо всех отправленных письмах.



На вкладке “Доступ” в раздел “Управление доступом” нажмите кнопку “Проверка подлинности”. В открывшемся окне отметьте галочкой пункт “Анонимный доступ” для того, чтобы все пользователи сервера и приложения могли использовать SMTP-сервер.



Далее, на вкладке “Доставка” нажмите кнопку “Дополнительно”. В открывшемся окне в поле “Полное доменное имя” введите ваше доменное имя или IP-адрес.

Свойства: [SMTP Virtual Server #1] ? X

Маршрутизация LDAP		Безопасность	
Общие	Доступ	Сообщения	Доставка
Исходящие Интервал первой повторной попытки (в минутах): 15 Интервал второй повторной попытки (в минутах): 30 Интервал третьей повторной попытки (в минутах): 60 Интервал последующей повторной попытки (в минутах): 240 Уведомление о задержке: 12 Часов Время ожидания: 2 Дней			
Локальные Уведомление о задержке: 12 Часов Время ожидания: 2 Дней			
Безопасность исходящих подключений... Исходящие подключения... Дополнительно...			
OK Отмена Применить Справка			

Дополнительные параметры доставки X

Максимальное количество прыжков: 15

Домен маскировки:

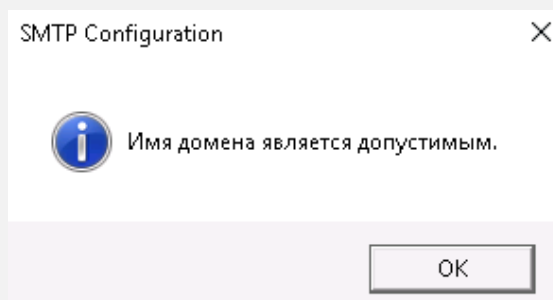
Полное доменное имя: example.org Проверка DNS

Промежуточный узел:

☐ Выполнять попытку прямой доставки перед отправкой на промежуточный узел
☐ Выполнять обратный поиск в DNS для входящих сообщений

OK Отмена Справка

При проверке DNS имя домена должно быть допустимым.



Сохраняем все внесенные изменения.

Автозапуск службы SMTPSVC

Служба SMTP-сервера должна запускаться автоматически при включении сервера, для этого откройте PowerShell и выполните следующие команды:

```
set-service smtpsvc -StartupType Automatic
```

Запустите службу:

```
start-service smtpsvc
```

Убедитесь, что служба SMTPSVC запущена:

```
get-service smtpsvc
```

```
Администратор: Windows PowerShell
Windows PowerShell
(C) Корпорация Майкрософт (Microsoft Corporation), 2016. Все права защищены.

PS C:\Users\Администратор.WIN-NP0VV3CC4I2> set-service smtpsvc -StartupType Automatic
PS C:\Users\Администратор.WIN-NP0VV3CC4I2> start-service smtpsvc
PS C:\Users\Администратор.WIN-NP0VV3CC4I2> get-service smtpsvc

Status      Name            DisplayName
-----
Running     smtpsvc         Протокол SMTP
```

Готово! :)

P.S. Мы не будем создавать никаких почтовых ящиков и делать переадресацию писем, так как для нас это не важно в рамках урока. Главное, чтобы наш SMTP-сервер находился в локальной сети, и мы могли его просканировать.

Энумерация SMTP

Мы также можем собрать информацию о хосте или сети с уязвимых почтовых серверов. Простой почтовый протокол SMTP поддерживает несколько интересных команд, таких как VRFY и EXPN. Запрос VRFY просит сервер проверить адрес электронной почты (почтовый ящик), в то время как EXPN запрашивает список псевдонимов. Этими запросами можно часто злоупотреблять для проверки существующих пользователей на почтовом сервере, что является полезной информацией во время теста на проникновение. Рассмотрим следующий пример:

```
kali@kali:~$ sudo nmap -p25 --script smtp-commands 192.168.0.115
```

```
(kali@kali)-[~]
$ sudo nmap -p25 --script smtp-commands 192.168.0.115
[sudo] password for kali:
Starting Nmap 7.91 ( https://nmap.org ) at 2022-07-28 13:18 EDT
Nmap scan report for 192.168.0.115
Host is up (0.00035s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
| smtp-commands: example.com Hello [192.168.0.172], TURN, SIZE 2097152, ETRN, PIPELI
NING, DSN, ENHANCEDSTATUSCODES, 8bitmime, BINARYMIME, CHUNKING, VRFY, OK,
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET MA
IL QUIT HELP AUTH TURN ETRN BDAT VRFY
MAC Address: 08:00:27:4A:71:AF (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.19 seconds
```


В результате выполнения команды мы получили информацию о том, что у нас открыт порт 25, получили список команд, которые поддерживает SMTP-сервер и другую полезную информацию. Теперь давайте отправим SMTP-серверу запрос VRFY:

```
kali@kali:~$ sudo nmap -p25 --script smtp-enum-users --script-args smtp-enum-users.methods={VRFY} 192.168.0.115
```

```
(kali@kali)-[~]
└─$ sudo nmap -p25 --script smtp-enum-users --script-args smtp-enum-users.methods={VRFY} 192.168.0.115
Starting Nmap 7.91 ( https://nmap.org ) at 2022-07-28 13:28 EDT
Nmap scan report for 192.168.0.115
Host is up (0.00038s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
| smtp-enum-users:
|_ Couldn't find any accounts
MAC Address: 08:00:27:4A:71:AF (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.16 seconds
```

Так как никакие почтовые ящики мы не настраивали - скрипт ничего не нашел! Но на "боевых" серверах все может быть "по-другому" :).

Фактически, ответ сервера на запрос VRFY - можно считать уязвимостью. Например, если вы обнаружите систему, в которой есть логин ([FTP](#), [Telnet](#) или другой), для которого требуется имя пользователя и пароль, и в той же сети или даже на самом сервере есть SMTP-сервер, то команда VRFY может дать подсказки для ввода имени пользователя.

Иногда самые «мелкие» уязвимости, зачастую утечки информации, могут объединяться в нечто более серьезное.

Давайте посмотрим, какие еще скрипты Nmap мы можем использовать против нашего SMTP-сервера:

```
kali@kali:~$ ls /usr/share/nmap/scripts | grep "smtp"
```

```
(kali@kali)-[~]  
$ ls /usr/share/nmap/scripts | grep "smtp"  
smtp-brute.nse  
smtp-commands.nse  
smtp-enum-users.nse  
smtp-ntlm-info.nse  
smtp-open-relay.nse  
smtp-strangeport.nse  
smtp-vuln-cve2010-4344.nse  
smtp-vuln-cve2011-1720.nse  
smtp-vuln-cve2011-1764.nse
```

Давайте посмотрим, что делает скрипт "smtp-open-relay.nse":

```
kali@kali:~$ nmap --script-help smtp-open-relay.nse
```

```
$ nmap --script-help smtp-open-relay.nse  
Starting Nmap 7.91 ( https://nmap.org ) at 2022-07-28 16:00 EDT  
  
smtp-open-relay  
Categories: discovery intrusive external  
https://nmap.org/nsedoc/scripts/smtp-open-relay.html  
Attempts to relay mail by issuing a predefined combination of SMTP commands. The goal of this script is to tell if a SMTP server is vulnerable to mail relaying.  
  
An SMTP server that works as an open relay, is a email server that does not verify if the user is authorised to send email from the specified email address. Therefore, users would be able to send email originating from any third-party email address that they want.  
  
The checks are done based in combinations of MAIL FROM and RCPT TO commands. The list is hardcoded in the source file. The script will output all the working combinations that the server allows if nmap is in verbose mode otherwise the script will print the number of successful tests. The script will not output if the server requires authentication.  
  
If debug is enabled and an error occurs while testing the target host, the error will be printed with the list of any combinations that were found prior to the error.
```

Цель этого сценария - определить, является ли SMTP-сервер уязвимым для ретрансляции почты. SMTP-сервер, работающий как открытый ретранслятор, — это почтовый сервер, который не проверяет, авторизован ли пользователь для отправки почты с указанного адреса. Таким образом, пользователи могут отправлять электронную почту с любого стороннего адреса электронной почты. Давайте попробуем запустить скрипт:

```
kali@kali:~$ sudo nmap -p25 --script smtp-open-relay 192.168.0.115
```

```
(kali㉿kali)-[~]  
$ sudo nmap -p25 --script smtp-open-relay 192.168.0.115  
[sudo] password for kali:  
Starting Nmap 7.91 ( https://nmap.org ) at 2022-07-28 16:09 EDT  
Nmap scan report for 192.168.0.115  
Host is up (0.00038s latency).  
  
PORT      STATE SERVICE  
25/tcp    open  smtp  
|_smtp-open-relay: Server is an open relay (3/16 tests)  
MAC Address: 08:00:27:4A:71:AF (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.19 seconds
```

Тесты показали, что сервер является открытым ретранслятором. Эта уязвимость представляет собой тип неправильной конфигурации, при которой каждый сможет использовать SMTP-сервер для рассылки своего СПАМА другим пользователям по всему миру.

Давайте вернемся к запросу VRFY и напишем программу на Python (обратите внимание – тут используется python версии 2) для автоматизированного поиска "правильных" имен пользователей. Рассмотрим программу, которая открывает TCP-сокеты, подключается к SMTP-серверу и делает запрос VRFY для определенного имени пользователя:

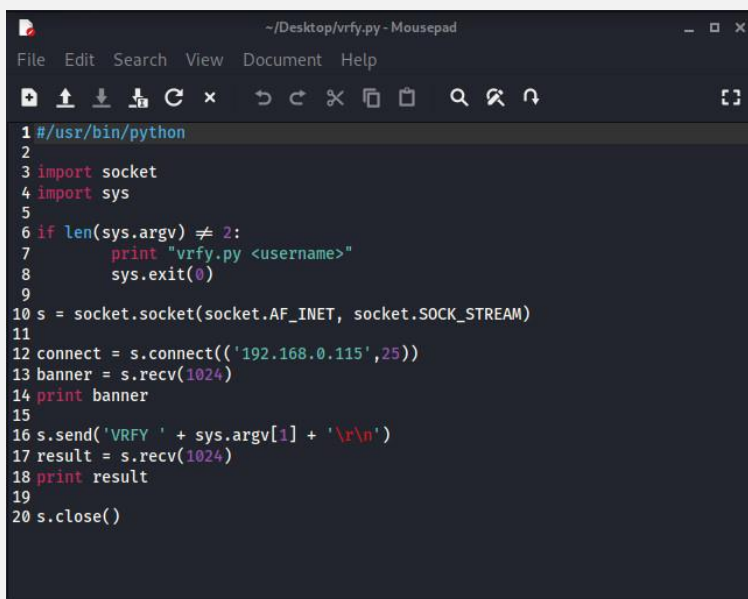
```
#!/usr/bin/python  
  
# Импортируем библиотеки  
import socket  
import sys  
  
# Подсказка как использовать  
if len(sys.argv) != 2:  
    print "vrfy.py <username>"  
    sys.exit(0)  
  
# Создаем сокет  
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
```

```
# Подключаемся к серверу
connect = s.connect(('192.168.0.115',25))
banner = s.recv(1024)

print banner

# Отправляем запрос VRFY
s.send('VRFY ' + sys.argv[1] + '\r\n')
result = s.recv(1024)
print result

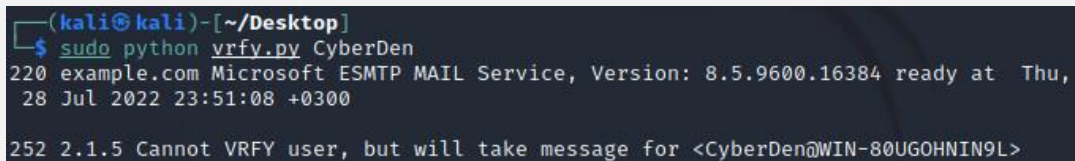
# Закрываем сокет
s.close()
```



```
~/Desktop/vrfy.py - Mousepad
File Edit Search View Document Help
1 #!/usr/bin/python
2
3 import socket
4 import sys
5
6 if len(sys.argv) != 2:
7     print "vrfy.py <username>"
8     sys.exit(0)
9
10 s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
11
12 connect = s.connect(('192.168.0.115',25))
13 banner = s.recv(1024)
14 print banner
15
16 s.send('VRFY ' + sys.argv[1] + '\r\n')
17 result = s.recv(1024)
18 print result
19
20 s.close()
```

Запускаем:

```
kali@kali:~$ sudo python vrfy.py CyberDen
```



```
(kali@kali)-[~/Desktop]
$ sudo python vrfy.py CyberDen
220 example.com Microsoft ESMTPL MAIL Service, Version: 8.5.9600.16384 ready at Thu,
28 Jul 2022 23:51:08 +0300

252 2.1.5 Cannot VRFY user, but will take message for <CyberDen@WIN-80UGOHNNIN9L>
```

Двигаемся дальше... :)

Файлы для скачивания:

[vrfy.py](#)

Команды, используемые в уроке:

```
kali@kali:~$ sudo nmap -p25 --script smtp-commands 192.168.0.115
```

```
kali@kali:~$ sudo nmap -p25 --script smtp-enum-users --script-args smtp-enum-users.methods={VRFY} 192.168.0.115
```

```
kali@kali:~$ ls /usr/share/nmap/scripts | grep "smtp"
```

```
kali@kali:~$ nmap --script-help smtp-open-relay.nse
```

```
kali@kali:~$ sudo nmap -p25 --script smtp-open-relay 192.168.0.115
```

```
kali@kali:~$ sudo python vrfy.py CyberDen
```